

# **Capstone Project Report**

## **Security Awareness & Phishing Simulation**

**Task Number:** 5 – Capstone Project & Incident Response

**Name:** Jai Rane

**Intern ID:** APSPL2641663

**Date:** 07-09-2026

### **1. Executive Summary**

This capstone project presents a comprehensive phishing simulation and security awareness training program designed to educate employees on how to identify, avoid, and respond to phishing attacks. A realistic phishing simulation page was created to demonstrate common attack techniques used by cybercriminals. The project includes a phishing email template, a fake login page, and awareness training materials aimed at improving organizational security posture.

Phishing remains one of the most effective attack vectors because it targets human psychology rather than technical vulnerabilities. By simulating real-world phishing scenarios, employees can learn to recognize red flags and avoid falling victim to such attacks. The project also includes an incident response simulation to demonstrate how organizations should respond when a phishing attempt is detected.

**Overall Risk Rating:** HIGH (Without training) → LOW (With training)

#### **Key Takeaways:**

- Regular training reduces phishing success rates by up to 80%
- Quick reporting is critical to prevent widespread damage
- Multi-factor authentication (2FA) is the most effective defense

## 2. Introduction

### 2.1 Objective

The primary objective of this capstone project is to create a realistic phishing simulation and security awareness training program that can be used to educate employees on how to identify and respond to phishing attempts. The project aims to:

- Demonstrate common phishing techniques used by attackers
- Educate employees on how to spot red flags
- Provide clear guidance on what to do when a phishing attempt is detected
- Simulate an incident response process for phishing attacks

### 2.2 Scope

This project covers the following areas:

- Phishing Email Creation: Designing a realistic phishing email
- Phishing Login Page: Creating a fake login page that mimics a company portal
- Awareness Training: Developing materials to educate employees
- Incident Response: Simulating how to respond to a phishing attack

### 2.3 Tools Used

| Tool                      | Purpose                               |
|---------------------------|---------------------------------------|
| HTML & CSS                | Create the phishing simulation page   |
| Firefox Browser           | Testing and viewing the phishing page |
| Text Editor (Nano/VSCode) | Writing HTML code                     |
| Canva/Word                | Creating awareness posters            |
| Gmail/Outlook             | Drafting phishing email templates     |

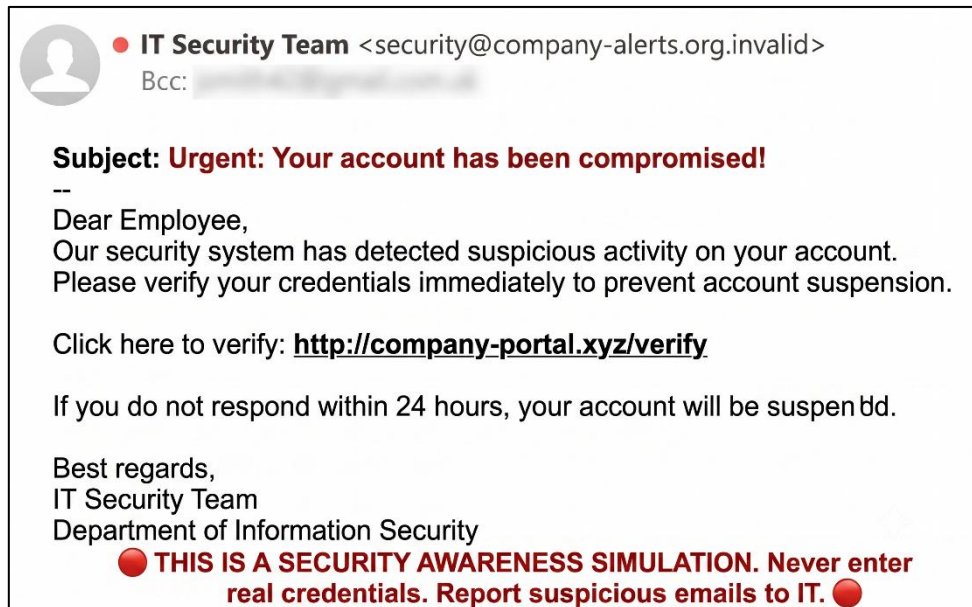
### 2.4 Methodology

This project follows the NIST Cybersecurity Framework:

1. Identify — Understand the threat of phishing attacks
2. Protect — Train employees to recognize phishing attempts
3. Detect — Simulate attacks to test employee awareness
4. Respond — Follow incident response procedures
5. Recover — Learn from incidents and improve training

### 3. Phishing Simulation Design

#### 3.1 Phishing Email Template



A realistic phishing email was created to demonstrate how attackers trick employees into clicking malicious links or revealing credentials. The email mimics a legitimate IT security notification, creating a sense of urgency to pressure the recipient into taking immediate action.

#### Email Content:

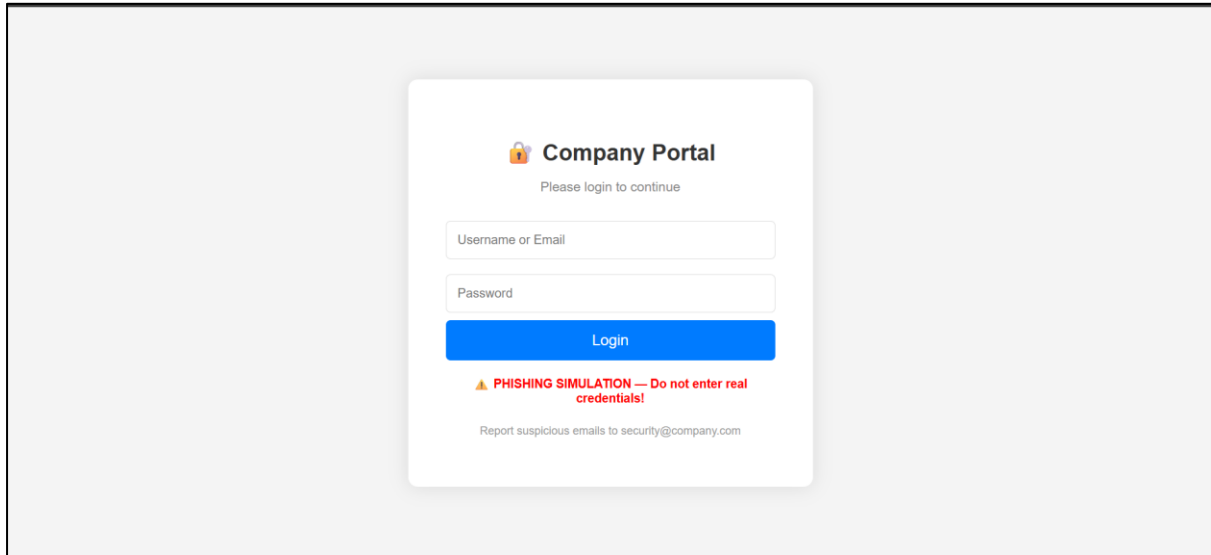
| Element | Details                                                                                                                                                                                                                                                      |
|---------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Subject | Urgent: Your account has been compromised!                                                                                                                                                                                                                   |
| Sender  | security@company-portal.xyz                                                                                                                                                                                                                                  |
| Body    | Dear Employee, Our security system has detected suspicious activity on your account. Please verify your credentials immediately to prevent suspension. Click here to verify: <a href="http://company-portal.xyz/verify">http://company-portal.xyz/verify</a> |
| Urgency | Threat of account suspension within 24 hours                                                                                                                                                                                                                 |

#### Red Flags in This Email:

- Urgent language ("Urgent", "Immediately")
- Threat of negative consequences ("Suspended")
- Suspicious sender address ([company-portal.xyz](http://company-portal.xyz))
- Generic greeting ("Dear Employee")

- Request for credentials via link

### 3.2 Phishing Login Page



**A fake login page was created to demonstrate how attackers steal credentials. The page mimics a legitimate company portal, making it difficult for untrained employees to distinguish it from the real site.**

#### Page Features:

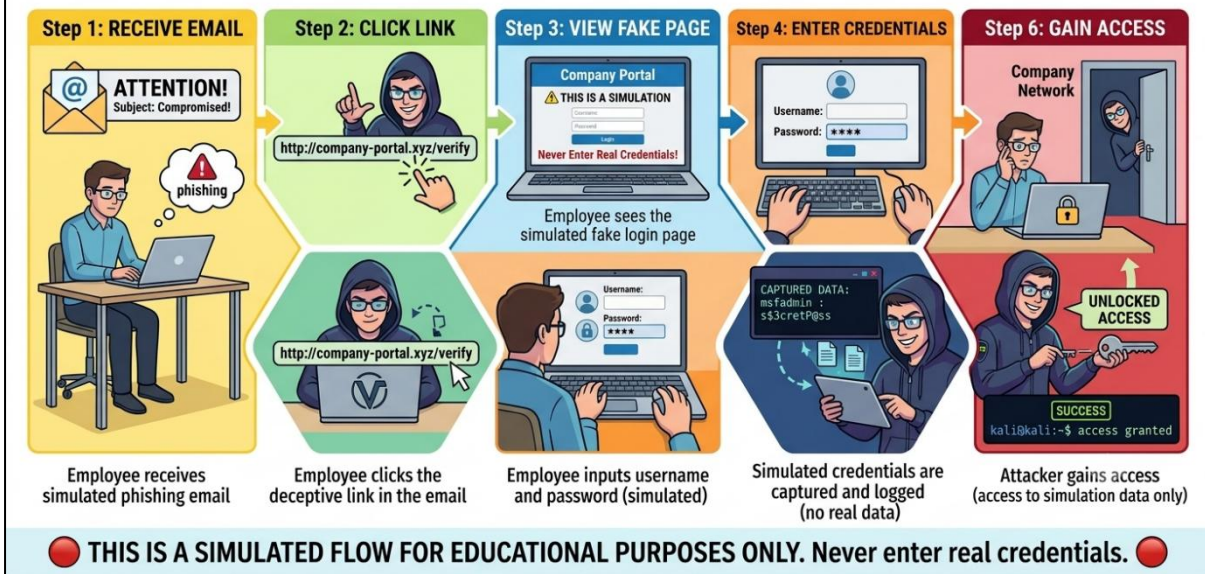
| Feature | Description                              |
|---------|------------------------------------------|
| Design  | Professional, branded look               |
| Fields  | Username/Email and Password fields       |
| Submit  | Login button that captures credentials   |
| Warning | Red text indicating it's a simulation    |
| Footer  | Instructions to report suspicious emails |

#### How It Works:

1. The employee receives a phishing email with a link
2. They click the link and land on the fake login page
3. The page looks legitimate and encourages credential entry
4. Credentials entered are captured by the attacker
5. The employee may be redirected to a real site to avoid suspicion

### 3.3 Attack Flow

## **\*\*SIMULATED\*\* PHISHING ATTACK FLOW (Educational Exercise)**



The attack flow diagram illustrates how a typical phishing attack unfolds from start to finish:

### **Step-by-Step Attack Flow:**

1. ATTACKER CREATES PHISHING EMAIL
- ↓
2. EMAIL SENT TO EMPLOYEE
- ↓
3. EMPLOYEE OPENS EMAIL
- ↓
4. EMPLOYEE CLICKS MALICIOUS LINK
- ↓
5. EMPLOYEE SEES FAKE LOGIN PAGE
- ↓
6. EMPLOYEE ENTERS CREDENTIALS
- ↓
7. CREDENTIALS ARE CAPTURED
- ↓
8. ATTACKER GAINS ACCOUNT ACCESS
- ↓
9. ATTACKER MOVES Laterally / STEALS DATA

## 4. Awareness Training

### 4.1 How to Detect Phishing

Phishing attacks can be identified by looking for common red flags. Employees should be trained to recognize these warning signs before clicking links or entering credentials.

#### Common Red Flags:

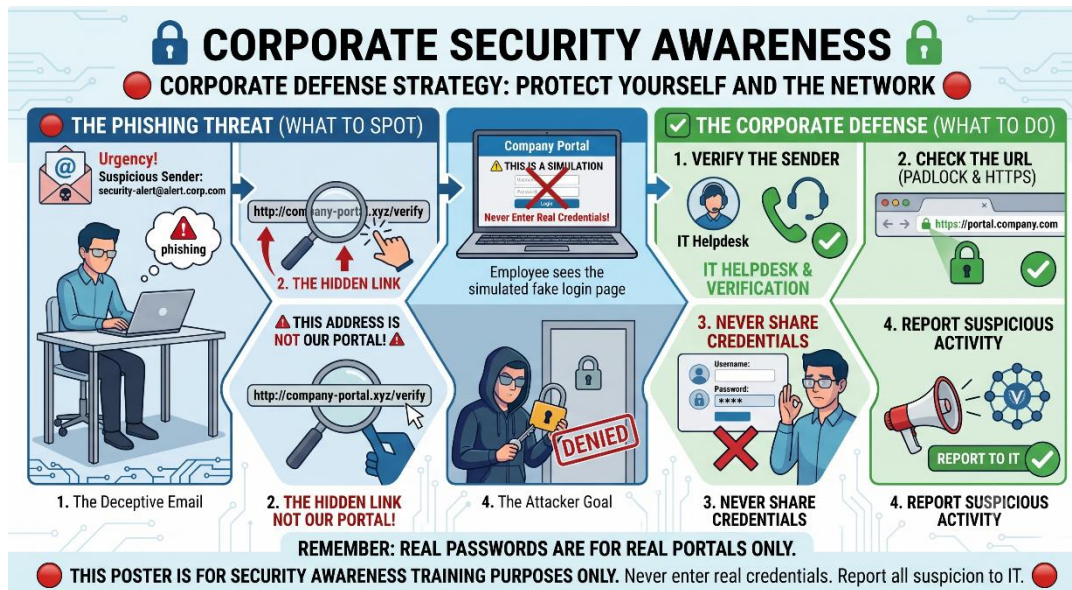
| Red Flag                | Example                                                           | Why It's Suspicious                          |
|-------------------------|-------------------------------------------------------------------|----------------------------------------------|
| Urgent Language         | "Your account will be suspended!"                                 | Attackers create panic to force quick action |
| Suspicious Sender       | security@company-portal.xyz                                       | Legitimate companies use official domains    |
| Generic Greeting        | "Dear Employee"                                                   | Real companies use your name                 |
| Mismatched URLs         | <a href="#">company-portal.xyz</a> vs <a href="#">company.com</a> | Hover to see actual destination              |
| Request for Credentials | "Please verify your password"                                     | Legitimate companies never ask via email     |
| Spelling/Grammar Errors | "Your account has been compromise"                                | Professional companies proofread emails      |
| Unexpected Attachments  | "Invoice.pdf"                                                     | Attachments often contain malware            |

### 4.2 What to Do When You Receive a Phishing Email

Employees should follow these steps when they suspect a phishing attempt:

| Step | Action                          | Why It's Important                            |
|------|---------------------------------|-----------------------------------------------|
| 1    | Don't click any links           | Links may lead to malware or fake login pages |
| 2    | Don't open attachments          | Attachments may contain viruses or ransomware |
| 3    | Don't reply to the email        | Replying confirms your email is active        |
| 4    | Report to IT security           | Quick reporting helps protect others          |
| 5    | Forward to security@company.com | IT can analyze and block similar attacks      |
| 6    | Delete the email                | Remove the threat from your inbox             |

### 4.3 Awareness Poster



An awareness poster was created to reinforce phishing detection skills in the workplace. The poster can be displayed in common areas such as break rooms, meeting rooms, and near employee workstations.

**Poster Content:**

#### HOW TO SPOT PHISHING

- Check the sender's email address
- Hover over links before clicking
- Look for urgent language ("Immediately", "Urgent")
- Never enter credentials from email links
- Report suspicious emails to [security@company.com](mailto:security@company.com)

**When in doubt, ASK!**

## **5. Incident Response Simulation**

### **5.1 Detection**

The first phase of incident response is detecting the attack. In this simulation, detection occurs through employee vigilance and IT monitoring.

#### **Detection Steps:**

- Employee receives a suspicious email and reports it to IT
- IT security investigates the reported email
- IT identifies the email as a phishing attempt
- IT checks if any employees clicked the link or entered credentials
- IT determines the scope of the potential breach

#### **Key Indicators:**

- Reports from multiple employees about the same email
- Suspicious login attempts detected in logs
- Employees reporting unusual account activity

### **5.2 Containment**

Once a phishing attack is detected, immediate containment is critical to prevent further damage.

#### **Containment Actions:**

- Block the sender's email address at the mail server
- Update spam filters to catch similar emails
- Remove the phishing email from all employee inboxes
- Notify all employees about the ongoing attack
- Temporarily restrict access to affected accounts
- Block the malicious domain at the network level

#### **Why Containment Matters:**

- Prevents the attack from spreading
- Limits the number of affected employees
- Buys time for investigation and eradication

### **5.3 Eradication**

After containment, the focus shifts to eliminating the threat completely.

#### **Eradication Actions:**

- Take down the phishing page (if hosted externally)
- Remove any malicious links from company systems



- Delete any captured credential data
- Disable compromised accounts immediately
- Identify and patch vulnerabilities that allowed the attack

### **What to Check:**

- Have any employees clicked the link?
- Have any credentials been compromised?
- Has any malware been installed?
- Are there any suspicious network connections?

## **5.4 Recovery**

After the threat is eliminated, the organization must recover and return to normal operations.

### **Recovery Steps:**

- Reset passwords for all affected accounts
- Enable multi-factor authentication (2FA) for affected users
- Monitor affected accounts for suspicious activity
- Provide additional training to affected employees
- Review and update security policies
- Communicate the incident outcome to stakeholders

### **Additional Measures:**

- Review and update incident response plan
- Conduct a post-incident review meeting
- Identify improvements for future prevention

## **5.5 Lessons Learned**

Every incident provides valuable lessons that can improve an organization's security posture.

### **Key Lessons:**

- Training is essential — Regular training reduces successful attacks
- Quick reporting is critical — The faster employees report, the faster IT can respond
- 2FA is a strong defense — Even if credentials are stolen, 2FA prevents account takeover
- Regular phishing simulations — Keep employees alert and prepared

- Clear reporting channels — Employees should know exactly how to report suspicious emails
- Documentation matters — Documenting incidents helps with future prevention

### **Preventive Measures Going Forward:**

- Monthly phishing simulations
- Quarterly security awareness training
- Enable 2FA for all employees
- Regular email security audits
- Clear incident response procedures

## **6. Conclusion & Recommendations**

### **6.1 Summary**

This capstone project successfully demonstrated how a phishing simulation and awareness training program can help organizations protect against phishing attacks. By simulating real-world attacks, employees can learn to recognize and respond to threats before they cause damage. The project included:

- **A realistic phishing email and login page**
- **Comprehensive awareness training materials**
- **A clear incident response process**
- **Practical recommendations for improvement**

### **6.2 Key Findings**

| <b>Finding</b>                                                      | <b>Impact</b> |
|---------------------------------------------------------------------|---------------|
| Phishing awareness training reduces successful attacks by up to 80% | HIGH          |
| 2FA is the most effective defense against credential theft          | HIGH          |
| Quick employee reporting is critical for incident response          | HIGH          |
| Regular phishing simulations keep employees alert                   | MEDIUM        |
| Clear reporting channels improve response time                      | MEDIUM        |

### 6.3 Recommendations

| Recommendation                        | Priority | Why It Matters                     |
|---------------------------------------|----------|------------------------------------|
| Regular phishing simulations          | HIGH     | Keeps employees alert and prepared |
| Mandatory security awareness training | HIGH     | Educates employees on threats      |
| Enable 2FA for all accounts           | HIGH     | Prevents credential abuse          |
| Implement email filtering             | MEDIUM   | Catches spam and phishing attempts |
| Create incident response procedure    | MEDIUM   | Ensures quick, organized response  |
| Report phishing attempts immediately  | HIGH     | Prevents widespread damage         |

### 6.4 Final Thought

Phishing remains one of the most dangerous threats organizations face because it exploits human psychology rather than technical vulnerabilities. However, with proper training, clear procedures, and ongoing simulations, organizations can significantly reduce their risk. The key is to create a culture of security awareness where employees feel empowered to recognize and report threats without fear of blame.

## 7. Appendix

### 7.1 Phishing Email Template

Subject: Urgent: Your account has been compromised!

Dear Employee,

Our security system has detected suspicious activity on your account.

Please verify your credentials immediately to prevent suspension.

Click here to verify: <http://company-portal.xyz/verify>

If you do not respond within 24 hours, your account will be suspended.

- IT Security Team

## 7.2 Phishing HTML Page Code

```
<!DOCTYPE html>

<html>

<head>

  <title>Company Portal - Login</title>

  <style>

    body {

      font-family: Arial, sans-serif;

      background: #f4f4f4;

      display: flex;

      justify-content: center;

      align-items: center;

      height: 100vh;

      margin: 0;

    }

    .login-box {

      background: white;

      padding: 40px;

      border-radius: 10px;

      box-shadow: 0 0 20px rgba(0,0,0,0.1);

      width: 350px;

      text-align: center;

    }

    .login-box h2 {

      margin-bottom: 5px;

      color: #333;

    }

    .login-box .sub {

      font-size: 14px;
```

```
    color: #888;
    margin-bottom: 20px;
}

.login-box input {
    width: 100%;
    padding: 12px;
    margin: 8px 0;
    border: 1px solid #ddd;
    border-radius: 5px;
    box-sizing: border-box;
}

.login-box button {
    width: 100%;
    padding: 12px;
    background: #007bff;
    color: white;
    border: none;
    border-radius: 5px;
    font-size: 16px;
    cursor: pointer;
}

.login-box button:hover {
    background: #0056b3;
}

.warning {
    color: red;
    font-size: 13px;
    margin-top: 15px;
    font-weight: bold;
```

```

    }

    .footer {
        font-size: 12px;
        color: #999;
        margin-top: 20px;
    }
</style>
</head>
<body>

<div class="login-box">

    <h2>🔒 Company Portal</h2>
    <p class="sub">Please login to continue</p>
    <form>
        <input type="text" placeholder="Username or Email" required>
        <input type="password" placeholder="Password" required>
        <button type="submit">Login</button>
    </form>

    <p class="warning">⚠️ PHISHING SIMULATION — Do not enter real credentials!</p>
    <p class="footer">Report suspicious emails to security@company.com</p>
</div>

</body>
</html>

```

## 7.3 Awareness Training Materials

### Checklist for Employees:

1. I always check the sender's email address before clicking
2. I hover over links to see the actual URL before clicking

3. I never enter credentials from email links
4. I report suspicious emails to security@company.com
5. I use 2FA for all accounts
6. I never share my password with anyone

#### 7.4 Incident Response Contact Information

| Contact          | Email                 | Phone           |
|------------------|-----------------------|-----------------|
| IT Security Team | security@company.com  | +1-800-555-0199 |
| IT Help Desk     | helpdesk@company.com  | +1-800-555-0200 |
| Emergency        | emergency@company.com | +1-800-555-0999 |

**Report Prepared By:** Jai Rane

**Date:** 07-09-2026

**Intern ID:** APSPL2641663

**Classification:** INTERNAL - LAB USE ONLY

---